Laboratorio 9

Sesión #9 Prácticas de contraseña segura (creación y gestión)

Título del Laboratorio: Prácticas de contraseña segura (creación y gestión)
Duración: 2 hora

Objetivos del Laboratorio:

1. Establecer Políticas de Contraseñas Seguras en un Entorno de TI
2. Implementar Mecanismos de Bloqueo de Cuenta tras Intentos Fallidos
3. Verificar y Documentar la Configuración de Seguridad de Contraseñas:

Materiales Necesarios:

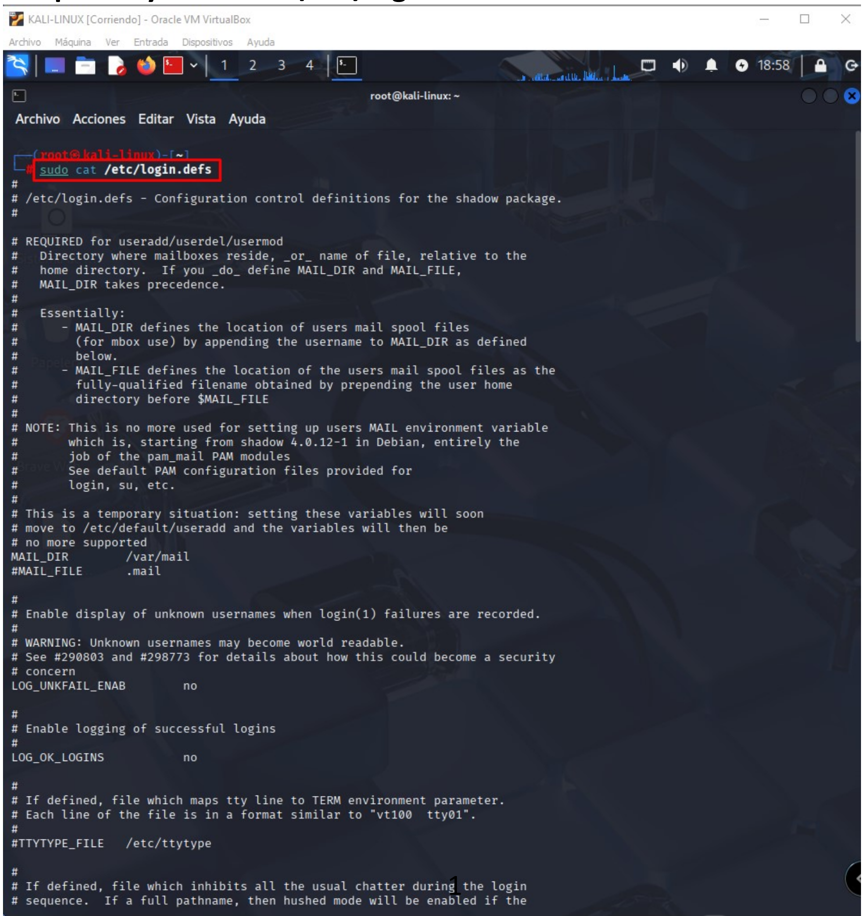
1. Utilizar GitHub como repositorio
2. Utilizar Academia Cisco
3. Computador
4. Acceso a internet

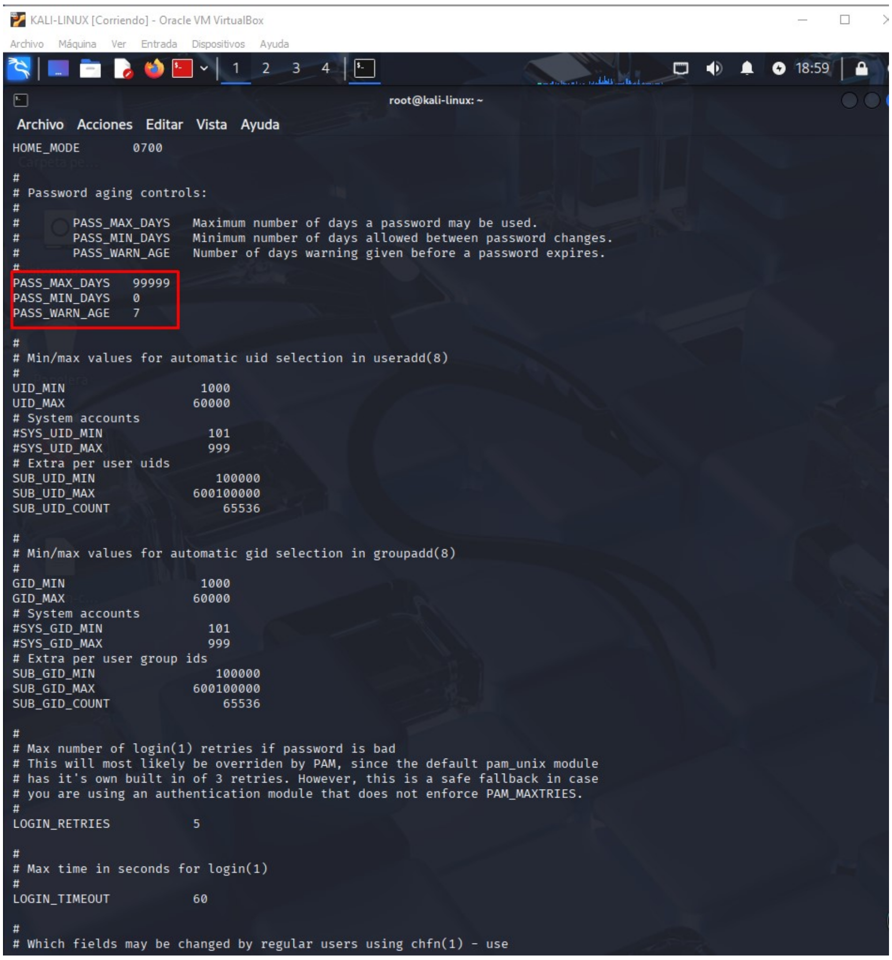
Estructura del Laboratorio:

Parte 1: Configuración de Políticas de Contraseñas Seguras

- **Paso 1:** Revisión de la Configuración Actual

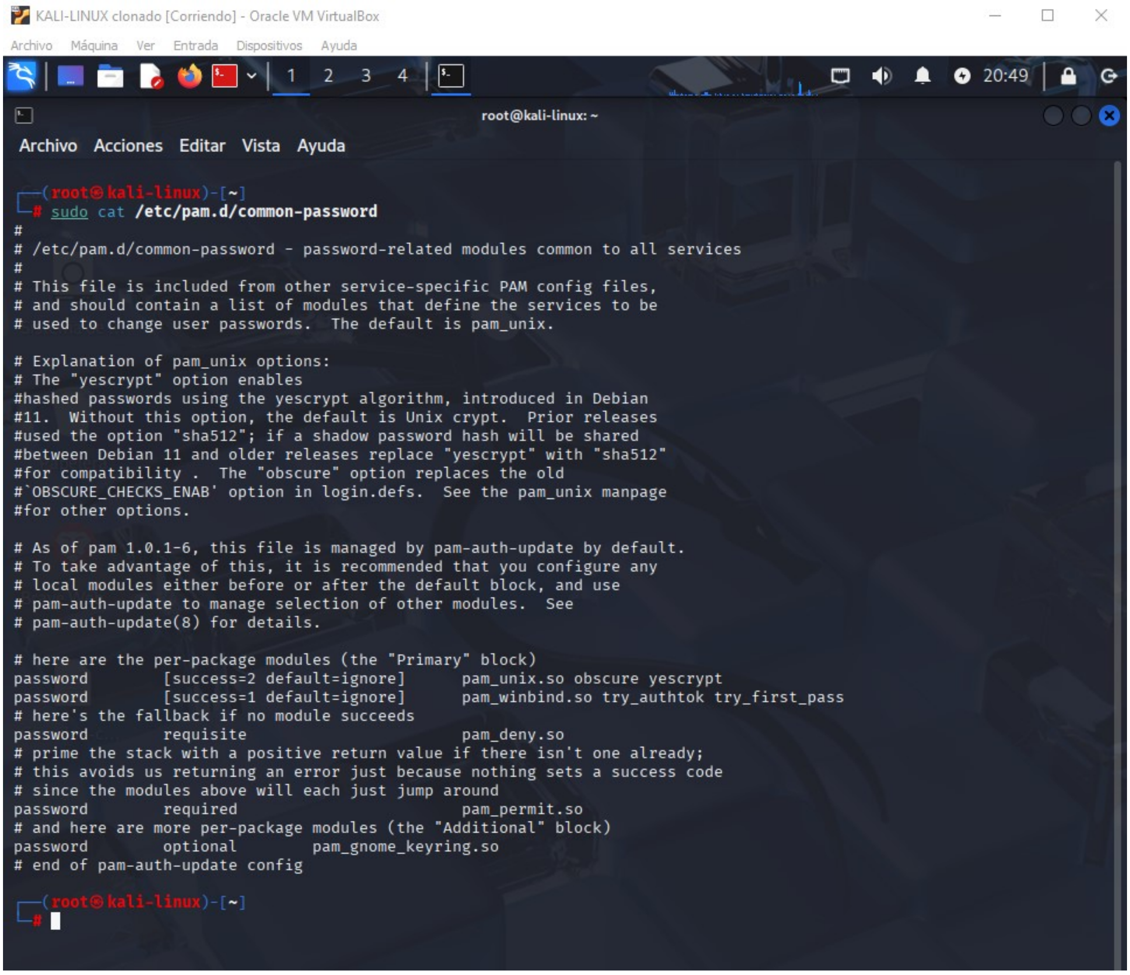
R//
Verificamos la política de contraseñas actual en Linux se realiza revisando el archivo de configuración pam.d y el archivo /etc/login.defs:





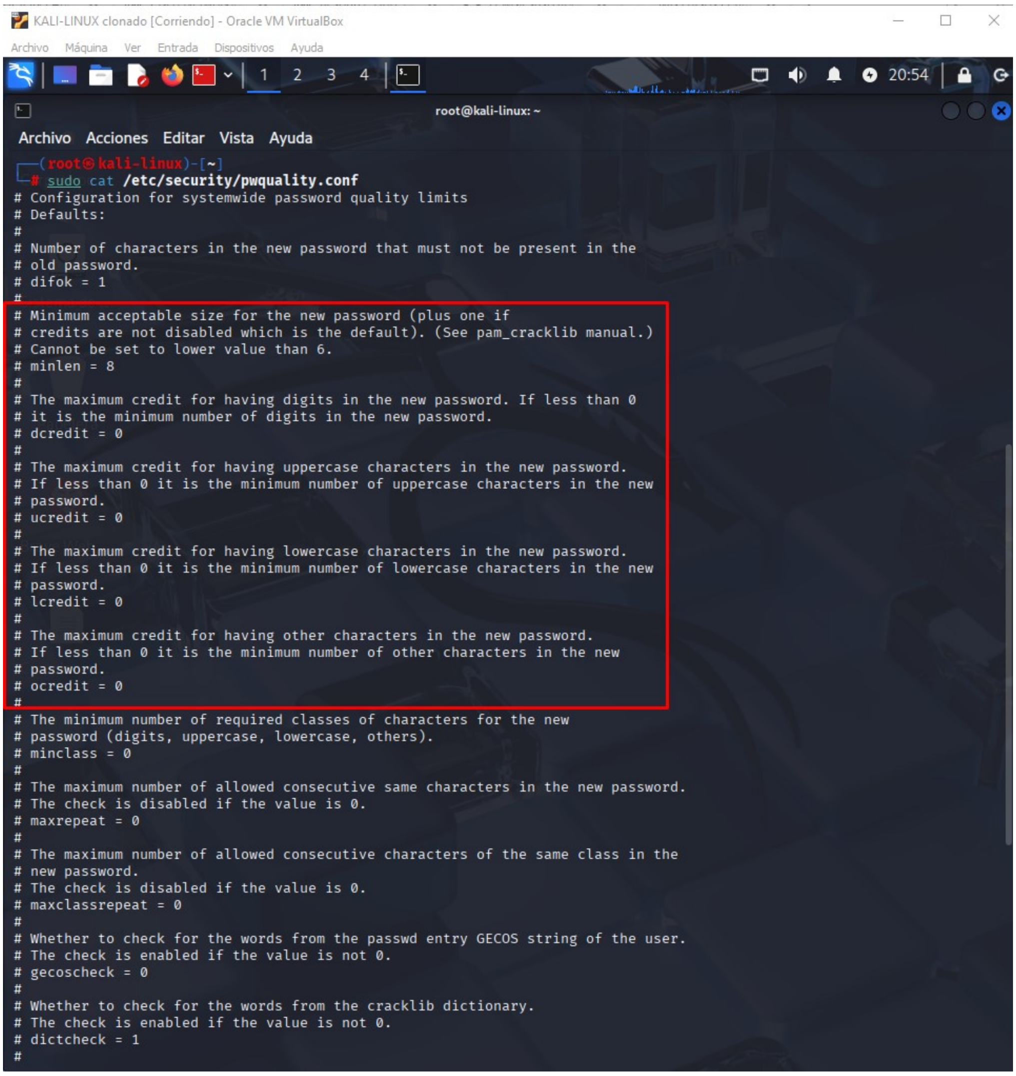
```
KALI-LINUX [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
1 2 3 4   18:59
root@kali-linux: ~
Archivo  Acciones  Editar  Vista  Ayuda
HOME_MODE       0700

#
# Password aging controls:
#
#       PASS_MAX_DAYS   Maximum number of days a password may be used.
#       PASS_MIN_DAYS   Minimum number of days allowed between password changes.
#       PASS_WARN_AGE   Number of days warning given before a password expires.
#
PASS_MAX_DAYS   99999
PASS_MIN_DAYS   0
PASS_WARN_AGE   7

#
# Min/max values for automatic uid selection in useradd(8)
#
UID_MIN                  1000
UID_MAX                 60000
# System accounts
#SYS_UID_MIN              101
#SYS_UID_MAX              999
# Extra per user uids
SUB_UID_MIN                100000
SUB_UID_MAX             600100000
SUB_UID_COUNT               65536

#
# Min/max values for automatic gid selection in groupadd(8)
#
GID_MIN                  1000
GID_MAX                 60000
# System accounts
#SYS_GID_MIN              101
#SYS_GID_MAX              999
# Extra per user group ids
SUB_GID_MIN                100000
SUB_GID_MAX             600100000
SUB_GID_COUNT               65536

#
# Max number of login(1) retries if password is bad
# This will most likely be overriden by PAM, since the default pam_unix module
# has it's own built in of 3 retries. However, this is a safe fallback in case
# you are using an authentication module that does not enforce PAM_MAXTRIES.
#
LOGIN_RETRIES           5

#
# Max time in seconds for login(1)
#
LOGIN_TIMEOUT           60

#
# Which fields may be changed by regular users using chfn(1) - use
```

sudo cat /etc/pam.d/common-password



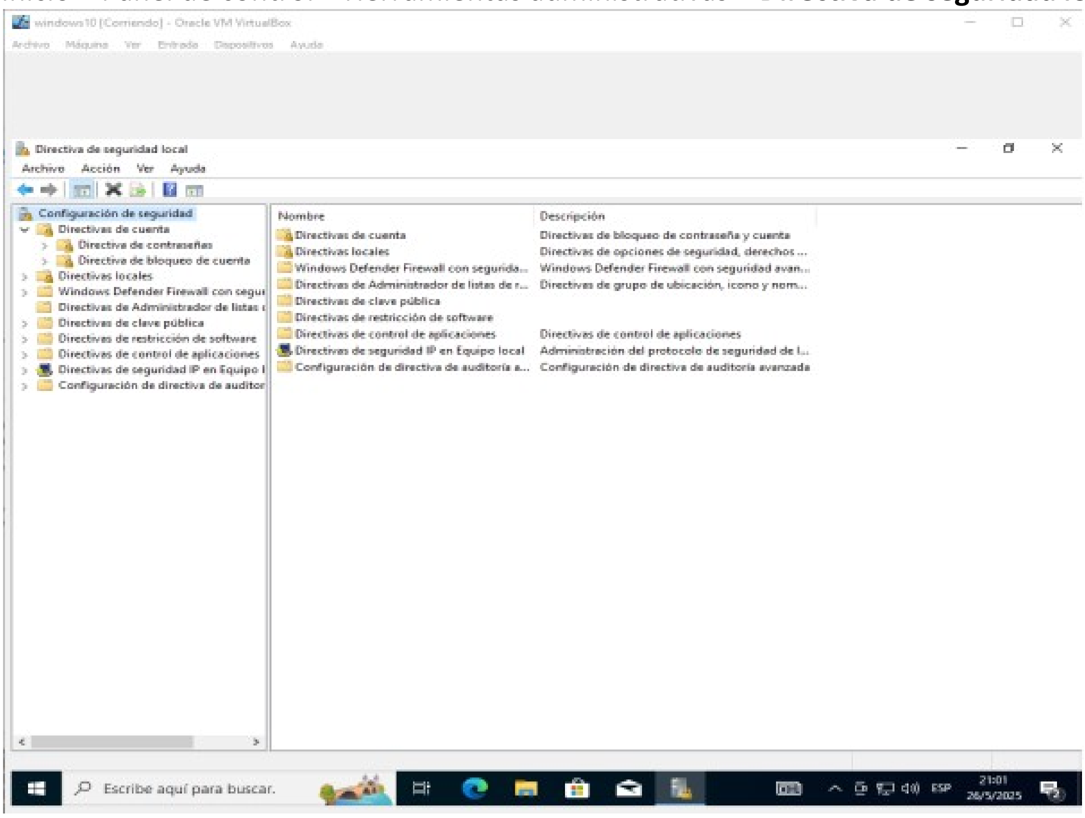
```
KALI-LINUX clonado [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
1 2 3 4   20:49
root@kali-linux: ~
Archivo  Acciones  Editar  Vista  Ayuda

┌──(root㉿kali-linux)-[~]
└─# sudo cat /etc/pam.d/common-password
#
# /etc/pam.d/common-password - password-related modules common to all services
#
# This file is included from other service-specific PAM config files,
# and should contain a list of modules that define the services to be
# used to change user passwords.  The default is pam_unix.

# Explanation of pam_unix options:
# The "yescrypt" option enables
#hashed passwords using the yescrypt algorithm, introduced in Debian
#11.  Without this option, the default is Unix crypt.  Prior releases
#used the option "sha512"; if a shadow password hash will be shared
#between Debian 11 and older releases replace "yescrypt" with "sha512"
#for compatibility .  The "obscure" option replaces the old
#`OBSCURE_CHECKS_ENAB' option in login.defs.  See the pam_unix manpage
#for other options.

# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules.  See
# pam-auth-update(8) for details.

# here are the per-package modules (the "Primary" block)
password        [success=2 default=ignore]      pam_unix.so obscure yescrypt
password        [success=1 default=ignore]      pam_winbind.so try_authtok try_first_pass
# here's the fallback if no module succeeds
password        requisite                       pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
password        required                        pam_permit.so
# and here are more per-package modules (the "Additional" block)
password        optional        pam_gnome_keyring.so
# end of pam-auth-update config

┌──(root㉿kali-linux)-[~]
└─#
```

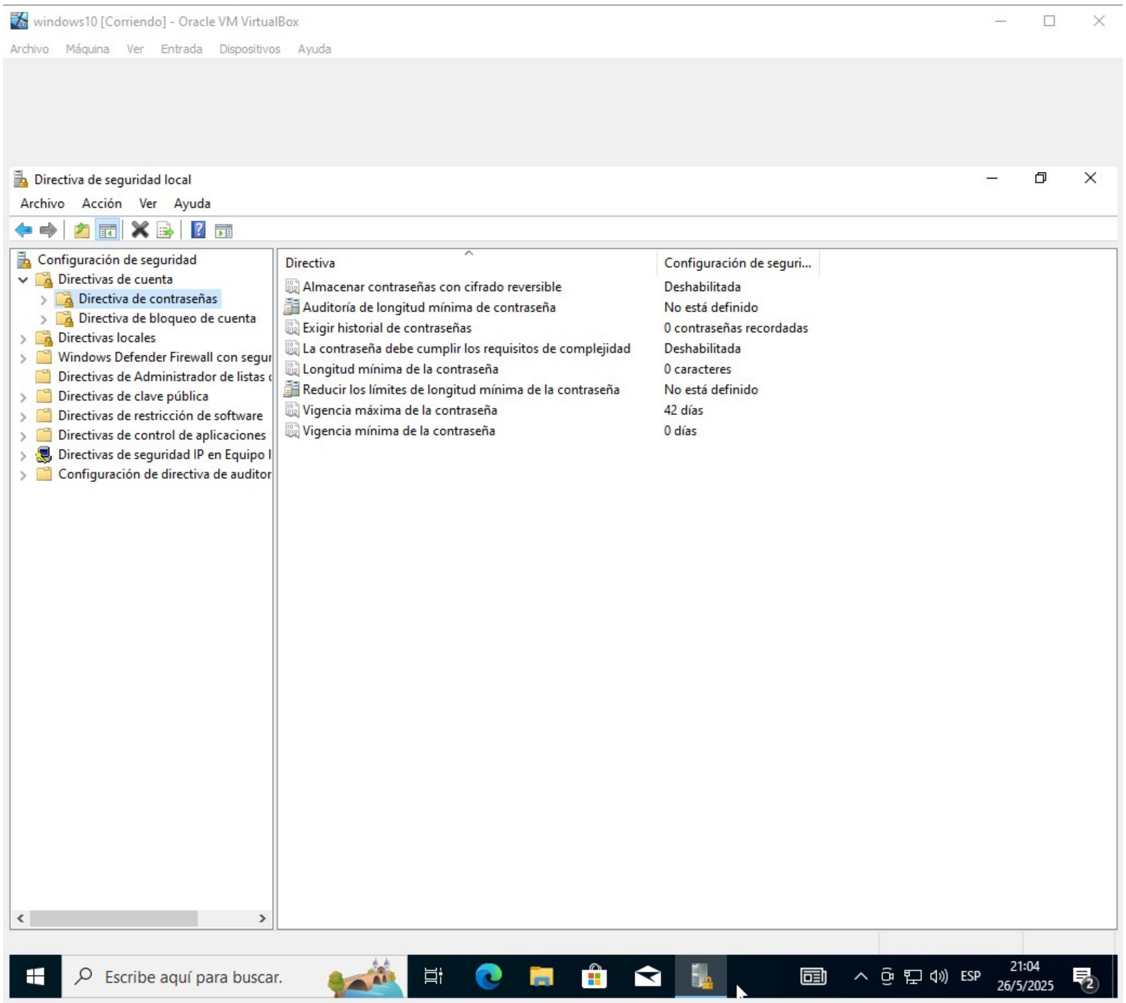
sudo cat /etc/security/pwquality.conf



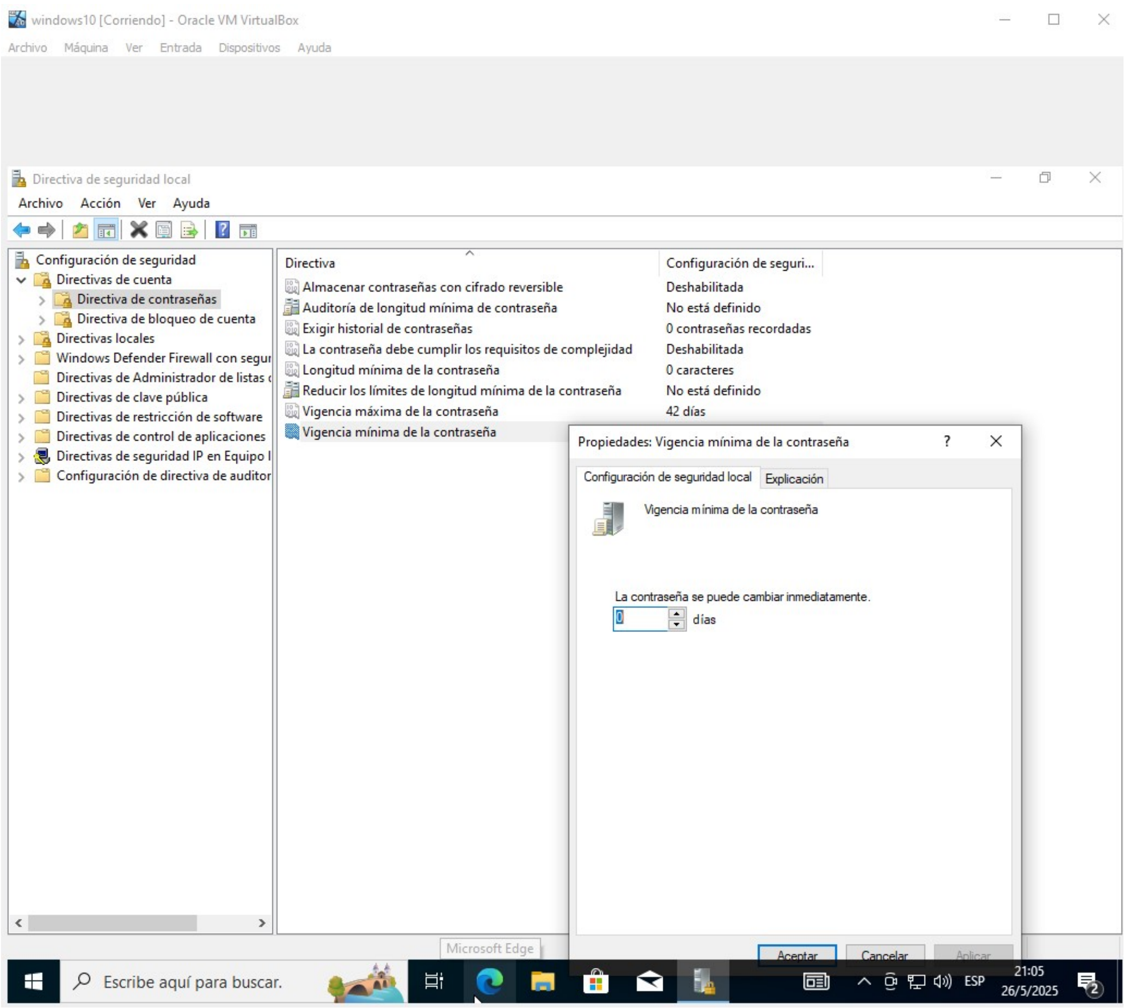
Windows:

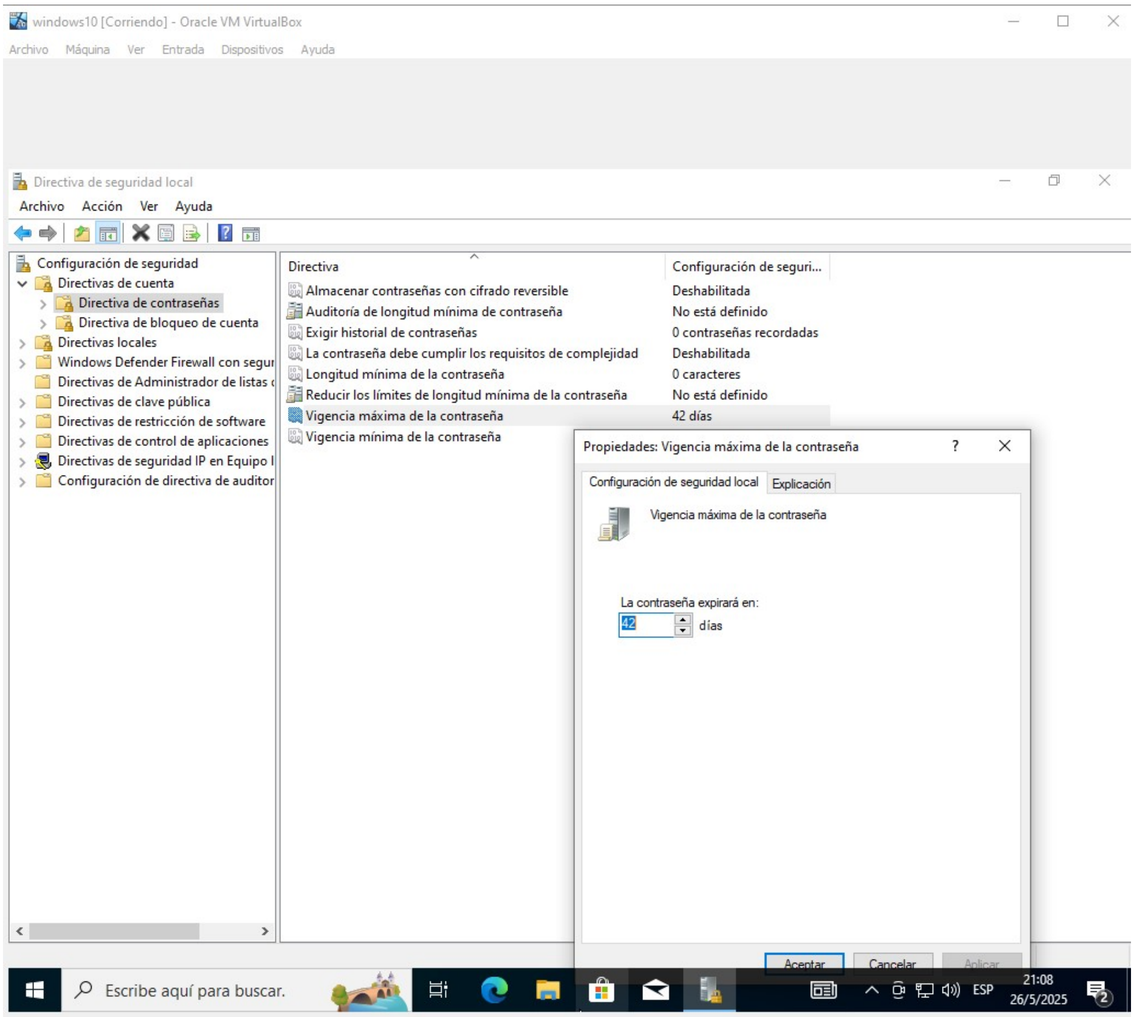
Ve a Inicio > Panel de control > Herramientas administrativas > **Directiva de seguridad local.**

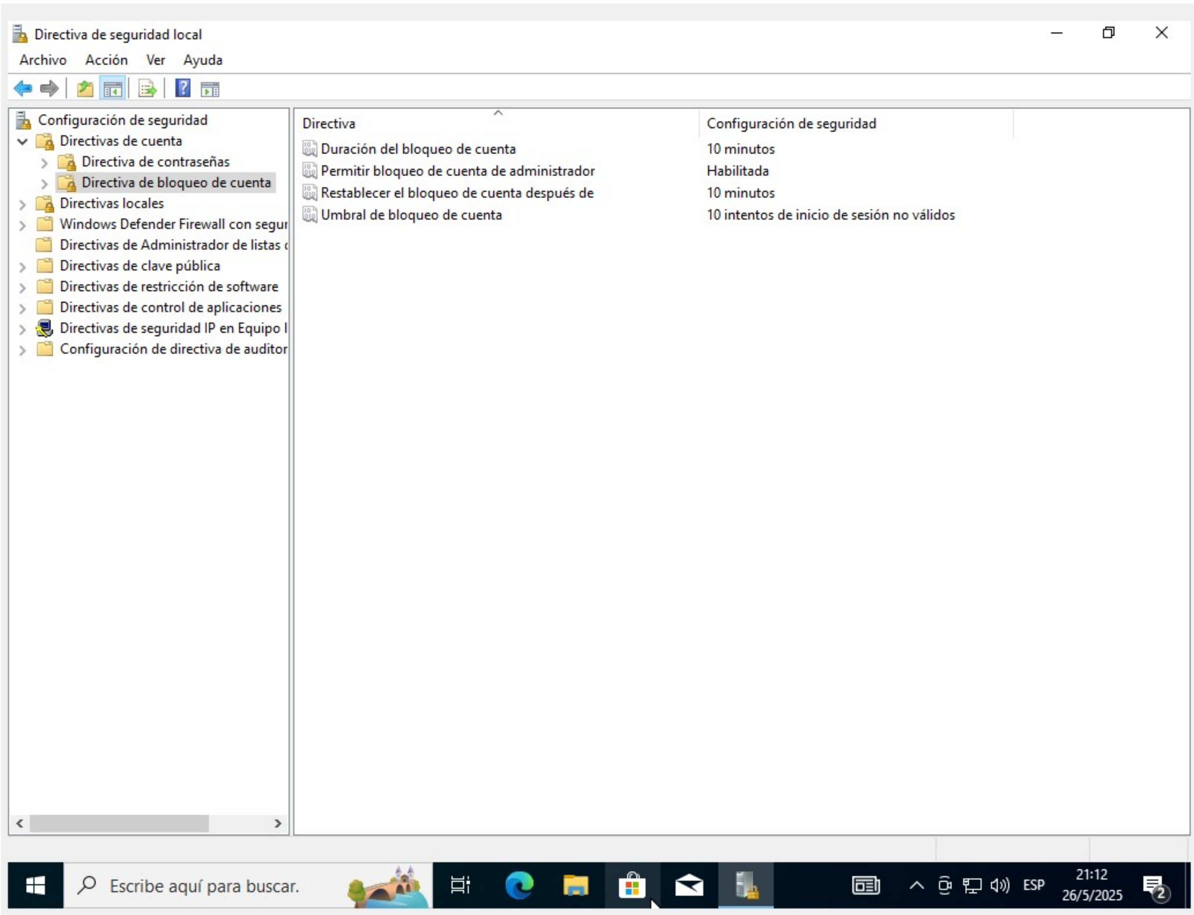



windows10 [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
Directiva de seguridad local
Archivo Acción Ver Ayuda
Configuración de seguridad
Directivas de cuenta
Directiva de contraseñas
Directiva de bloqueo de cuenta
Directivas locales
Windows Defender Firewall con segur
Directivas de Administrador de listas
Directivas de clave pública
Directivas de restricción de software
Directivas de control de aplicaciones
Directivas de seguridad IP en Equipo l
Configuración de directiva de auditor
Directiva
Configuración de seguri...
Almacenar contraseñas con cifrado reversible
Deshabilitada
Auditoría de longitud mínima de contraseña
No está definido
Exigir historial de contraseñas
0 contraseñas recordadas
La contraseña debe cumplir los requisitos de complejidad
Deshabilitada
Longitud mínima de la contraseña
0 caracteres
Reducir los límites de longitud mínima de la contraseña
No está definido
Vigencia máxima de la contraseña
42 días
Vigencia mínima de la contraseña
0 días
Escribe aquí para buscar.
ESP
21:04
26/5/2025

--


windows10 [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
Directiva de seguridad local
Archivo Acción Ver Ayuda
Configuración de seguridad
Directivas de cuenta
Directiva de contraseñas
Directiva de bloqueo de cuenta
Directivas locales
Windows Defender Firewall con segur
Directivas de Administrador de listas
Directivas de clave pública
Directivas de restricción de software
Directivas de control de aplicaciones
Directivas de seguridad IP en Equipo l
Configuración de directiva de auditor
Directiva
Configuración de seguri...
Almacenar contraseñas con cifrado reversible
Deshabilitada
Auditoría de longitud mínima de contraseña
No está definido
Exigir historial de contraseñas
0 contraseñas recordadas
La contraseña debe cumplir los requisitos de complejidad
Deshabilitada
Longitud mínima de la contraseña
0 caracteres
Reducir los límites de longitud mínima de la contraseña
No está definido
Vigencia máxima de la contraseña
42 días
Vigencia mínima de la contraseña
Propiedades: Vigencia mínima de la contraseña
Configuración de seguridad local
Explicación
Vigencia mínima de la contraseña
La contraseña se puede cambiar inmediatamente.
0
días
Aceptar
Cancelar
Aplicar
Microsoft Edge
Escribe aquí para buscar.
ESP
21:05
26/5/2025

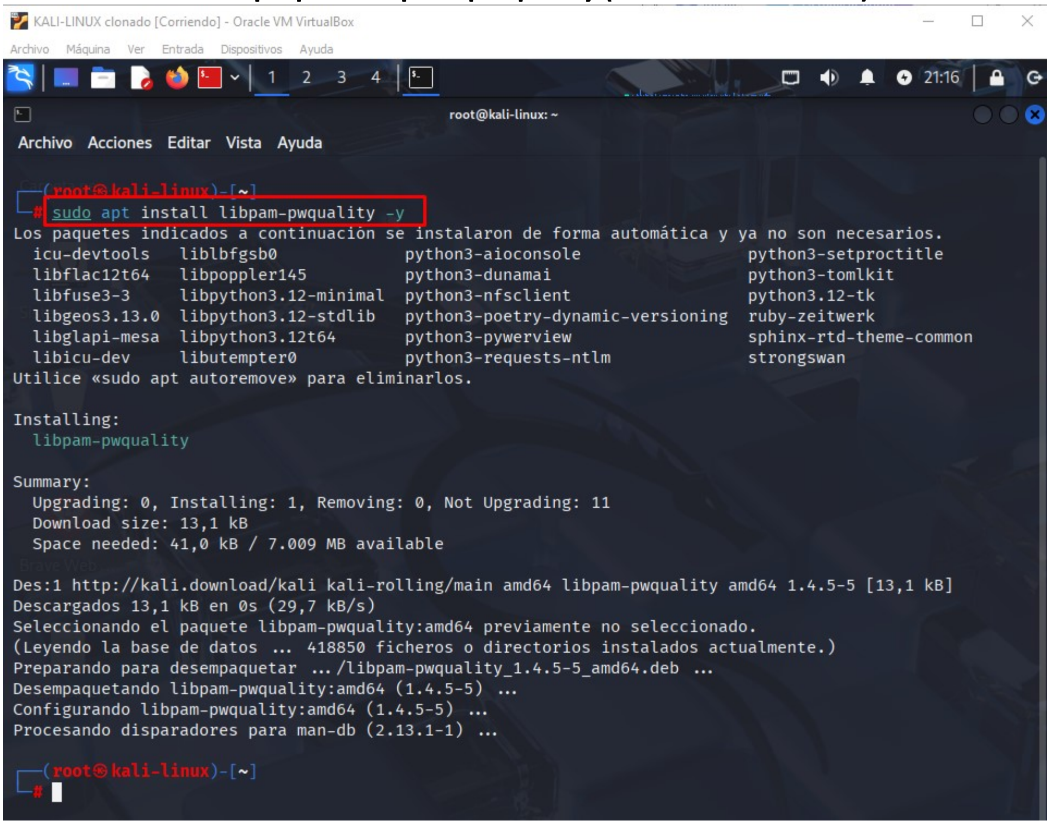

windows10 [Corriendo] - Oracle VM VirtualBox
Archivo Máquina Ver Entrada Dispositivos Ayuda
Directiva de seguridad local
Archivo Acción Ver Ayuda
Configuración de seguridad
Directivas de cuenta
Directiva de contraseñas
Directiva de bloqueo de cuenta
Directivas locales
Windows Defender Firewall con segur
Directivas de Administrador de listas
Directivas de clave pública
Directivas de restricción de software
Directivas de control de aplicaciones
Directivas de seguridad IP en Equipo l
Configuración de directiva de auditor
Directiva
Configuración de seguri...
Almacenar contraseñas con cifrado reversible
Deshabilitada
Auditoría de longitud mínima de contraseña
No está definido
Exigir historial de contraseñas
0 contraseñas recordadas
La contraseña debe cumplir los requisitos de complejidad
Deshabilitada
Longitud mínima de la contraseña
0 caracteres
Reducir los límites de longitud mínima de la contraseña
No está definido
Vigencia máxima de la contraseña
42 días
Vigencia mínima de la contraseña
Propiedades: Vigencia máxima de la contraseña
Configuración de seguridad local
Explicación
Vigencia máxima de la contraseña
La contraseña expirará en:
42
días
Aceptar
Cancelar
Aplicar
Escribe aquí para buscar.
ESP
21:08
26/5/2025


Directiva de seguridad local
Archivo Acción Ver Ayuda
Configuración de seguridad
Directivas de cuenta
Directiva de contraseñas
Directiva de bloqueo de cuenta
Directivas locales
Windows Defender Firewall con segur
Directivas de Administrador de listas
Directivas de clave pública
Directivas de restricción de software
Directivas de control de aplicaciones
Directivas de seguridad IP en Equipo l
Configuración de directiva de auditor
Directiva
Configuración de seguridad
Duración del bloqueo de cuenta
10 minutos
Permitir bloqueo de cuenta de administrador
Habilitada
Restablecer el bloqueo de cuenta después de
10 minutos
Umbral de bloqueo de cuenta
10 intentos de inicio de sesión no válidos
Escribe aquí para buscar.
ESP
21:12
26/5/2025

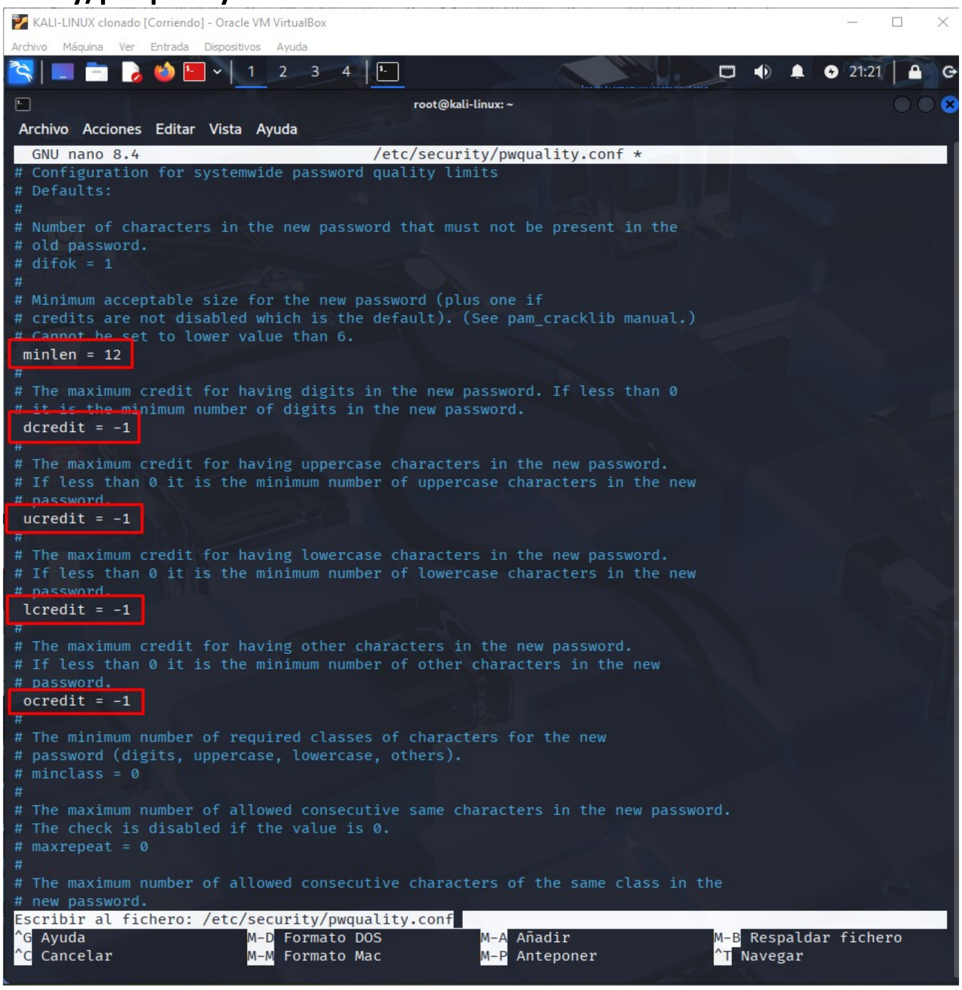
Paso 2: Configuración de la Longitud Mínima y Complejidad de las Contraseñas

R//

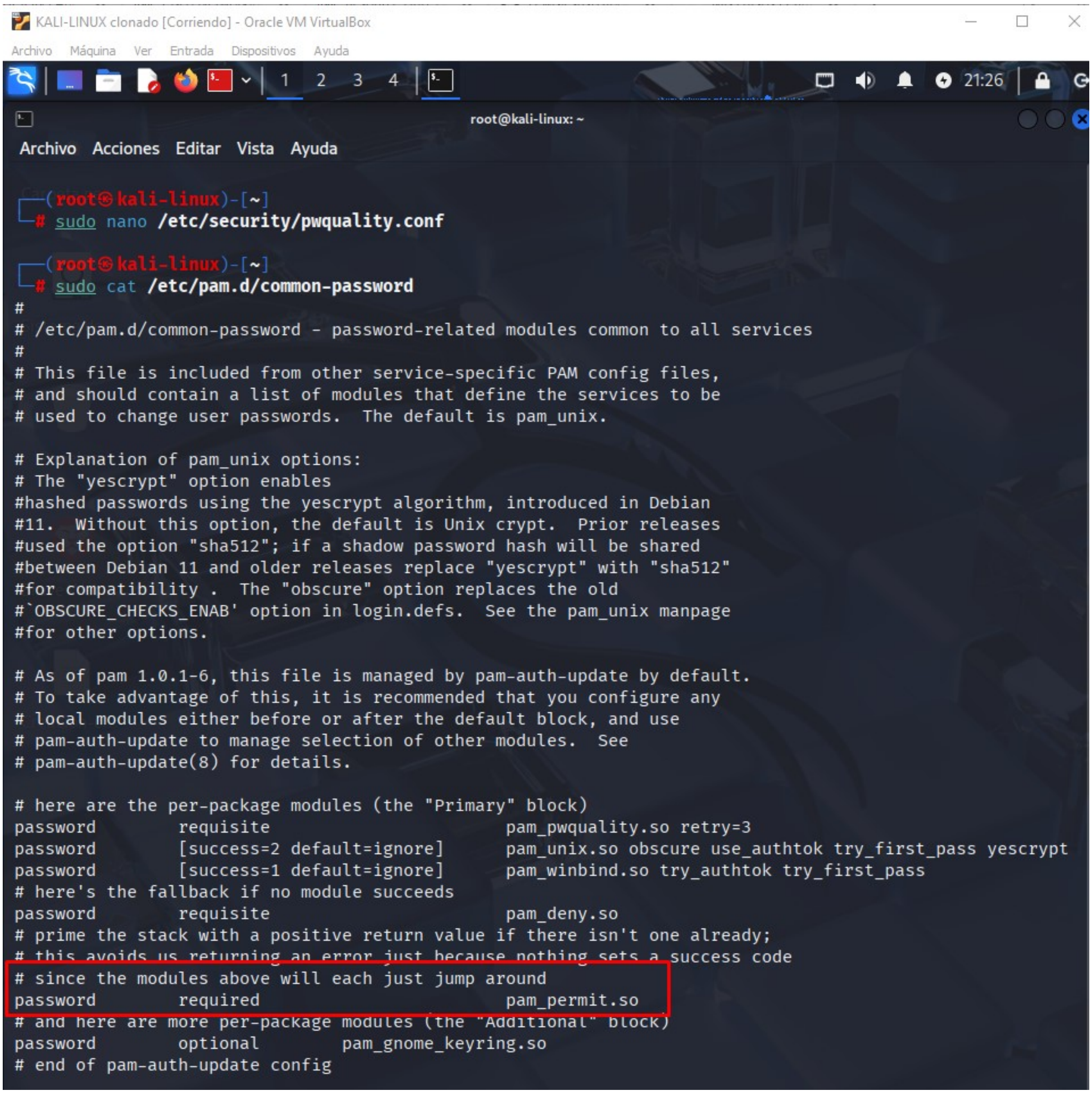
Procedemos a instalar el paquete libpam-pwquality (si no está instalado):



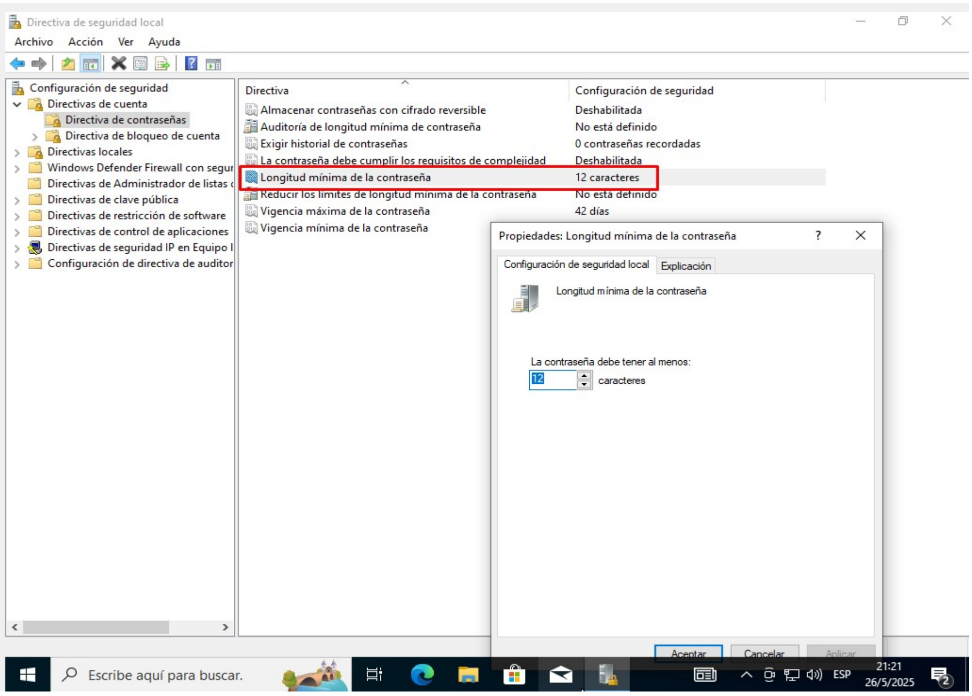
Procedemos a configurar la longitud mínima y la complejidad de las contraseñas en el archivo /etc/security/pwquality.conf:

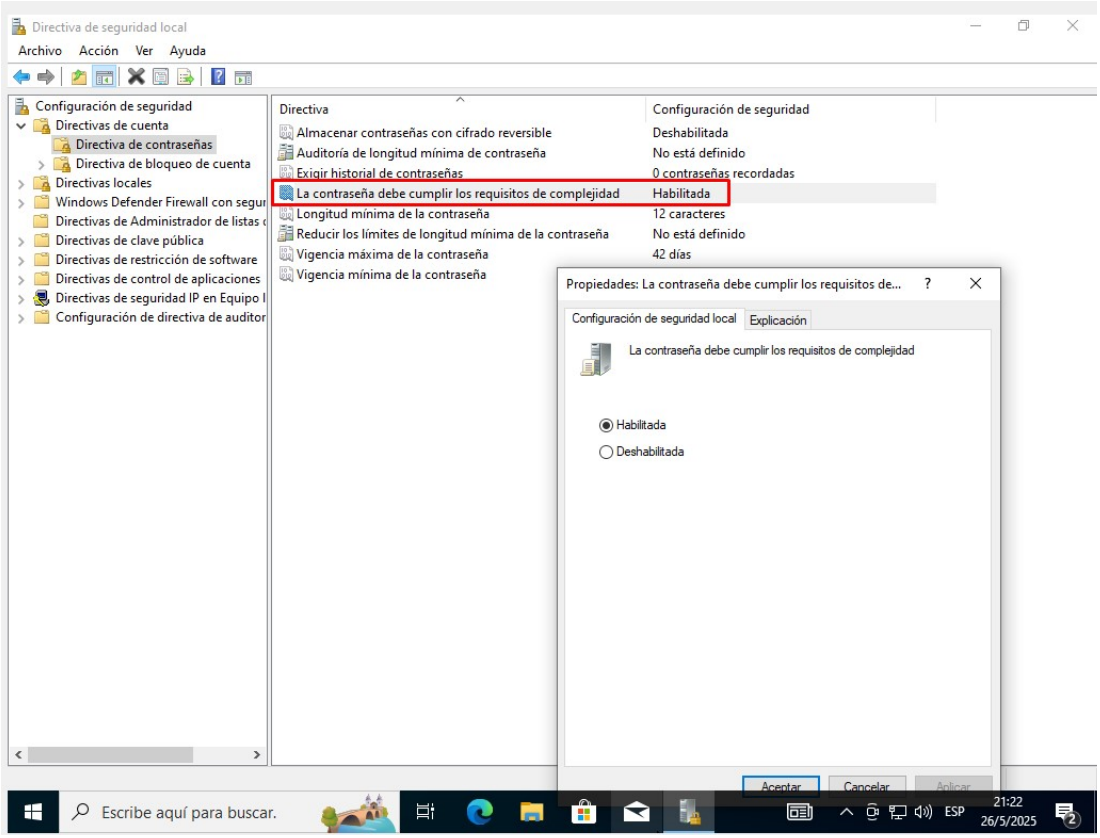


Visualizamos el archivo /etc/pam.d/common-password para que use el módulo pam_pwquality.so:



Windows:





Parte 2: Configuración de Bloqueo de Cuenta tras Intentos Fallidos

- **Paso 3:** Implementación del Bloqueo de Cuenta

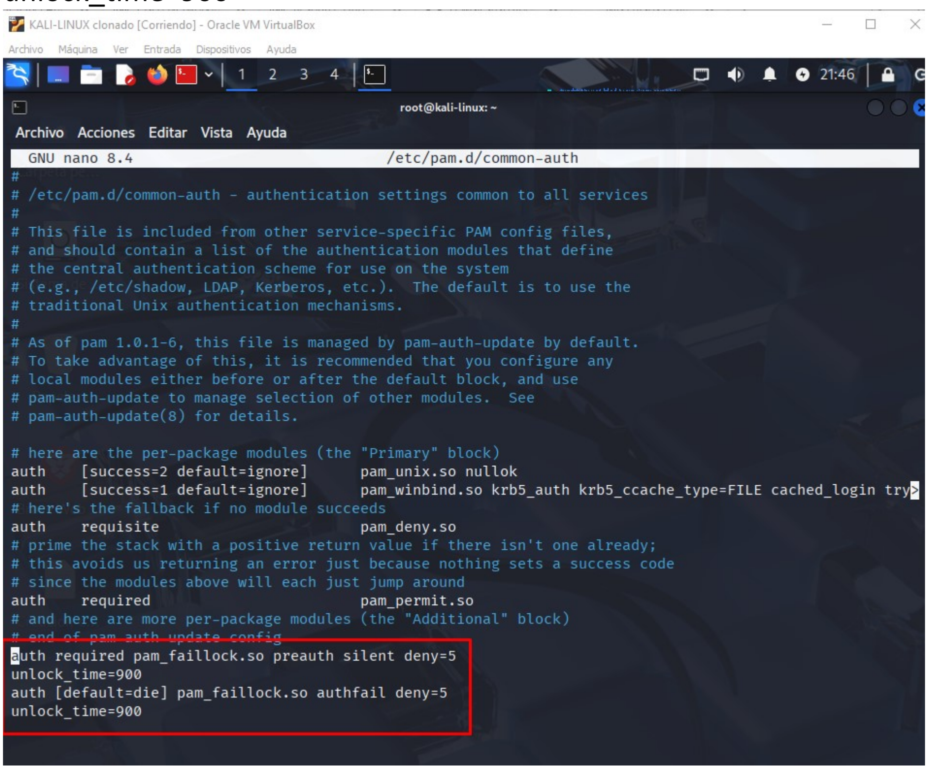
R//

Para implementar el bloqueo de cuenta en Linux, puedes usar pam_tally2 o pam_faillock, dependiendo de la distribución.

Con pam_faillock, abre el archivo /etc/pam.d/common-auth y añade:

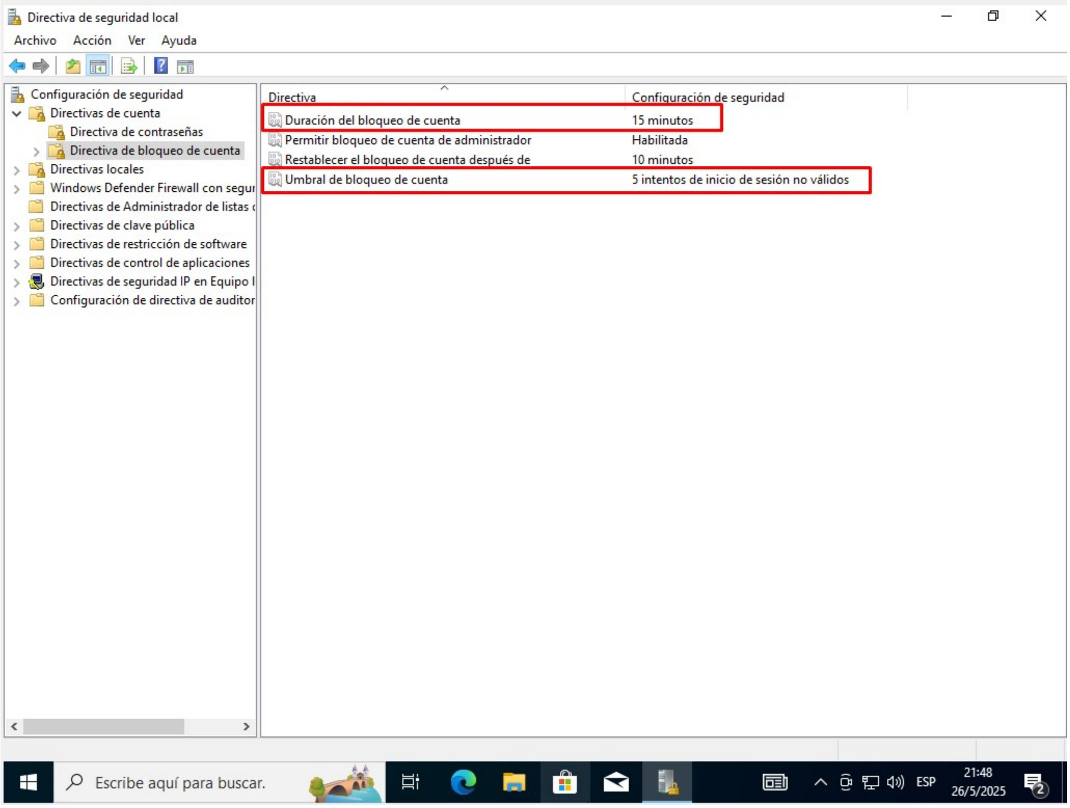
Esto bloqueará la cuenta tras 5 intentos fallidos durante 15 minutos (900 segundos).

auth required pam_faillock.so preauth silent deny=5
unlock_time=900
auth [default=die] pam_faillock.so authfail deny=5
unlock_time=900



Configura:

- Umbral de bloqueo de cuenta a 5 intentos.
- Duración del bloqueo de cuenta a 15 minutos.

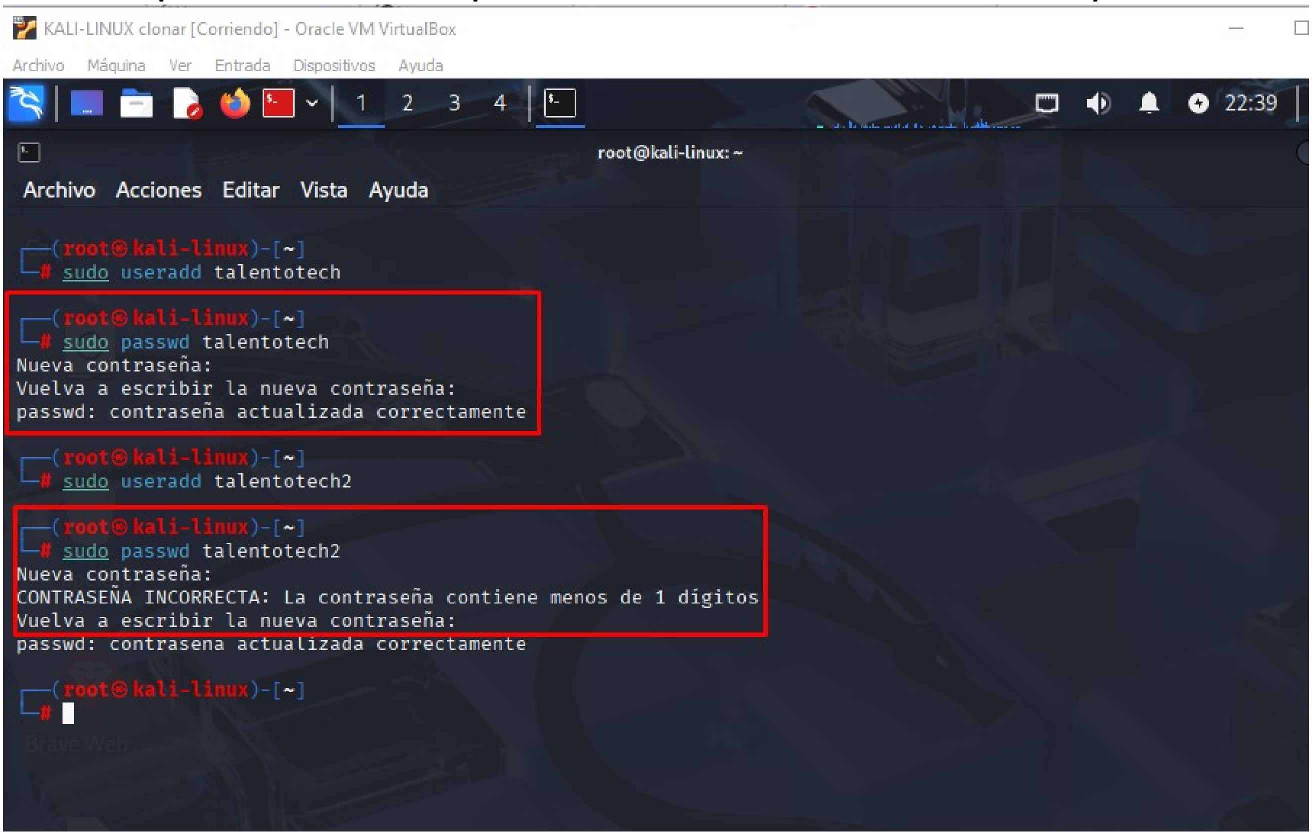


Parte 3: Verificación y Documentación de la Configuración

- **Paso 4:** Verificación de la Configuración de Contraseñas

R//

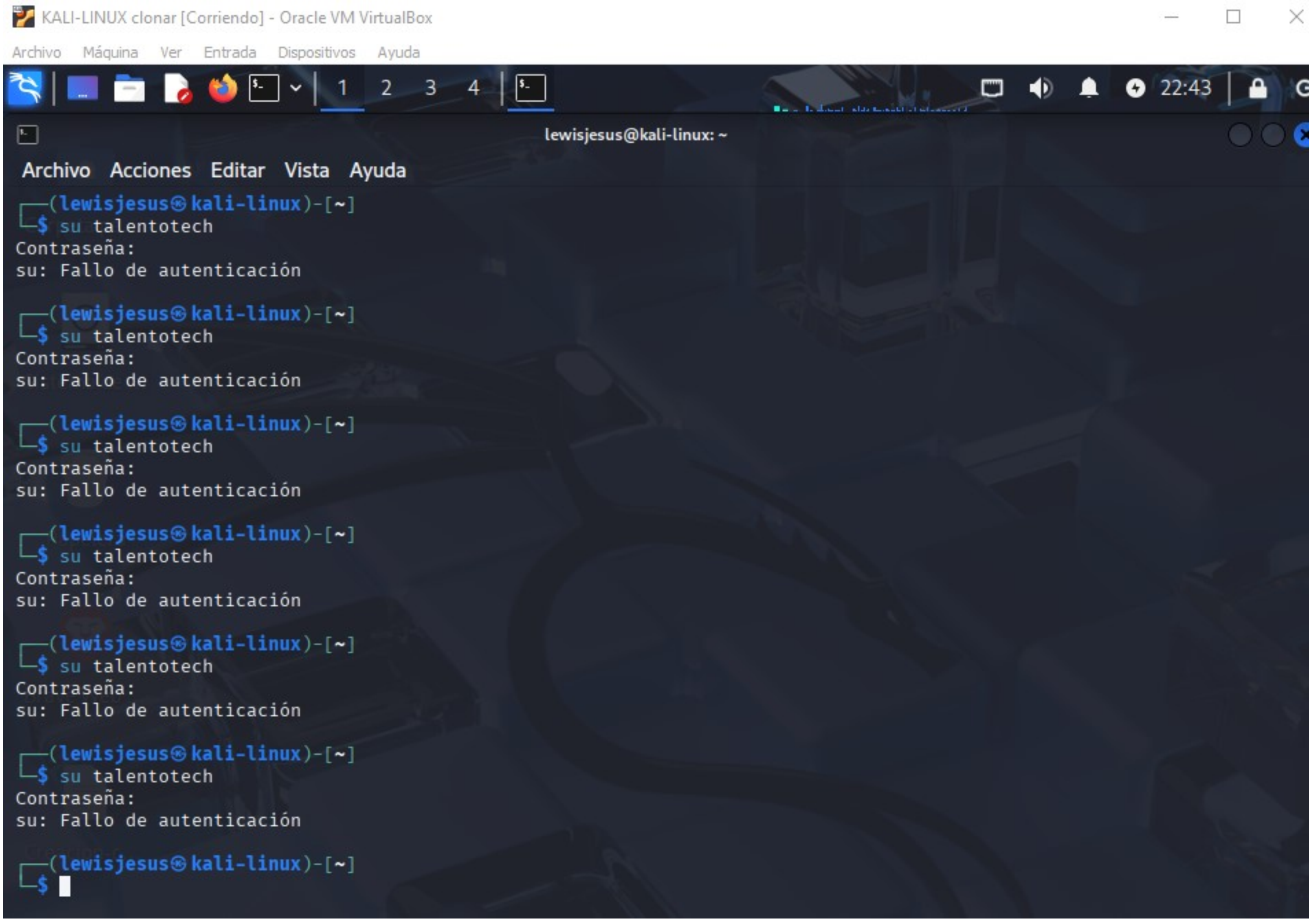
verificar la política de contraseñas probando crear o cambiar una contraseña con passwd:



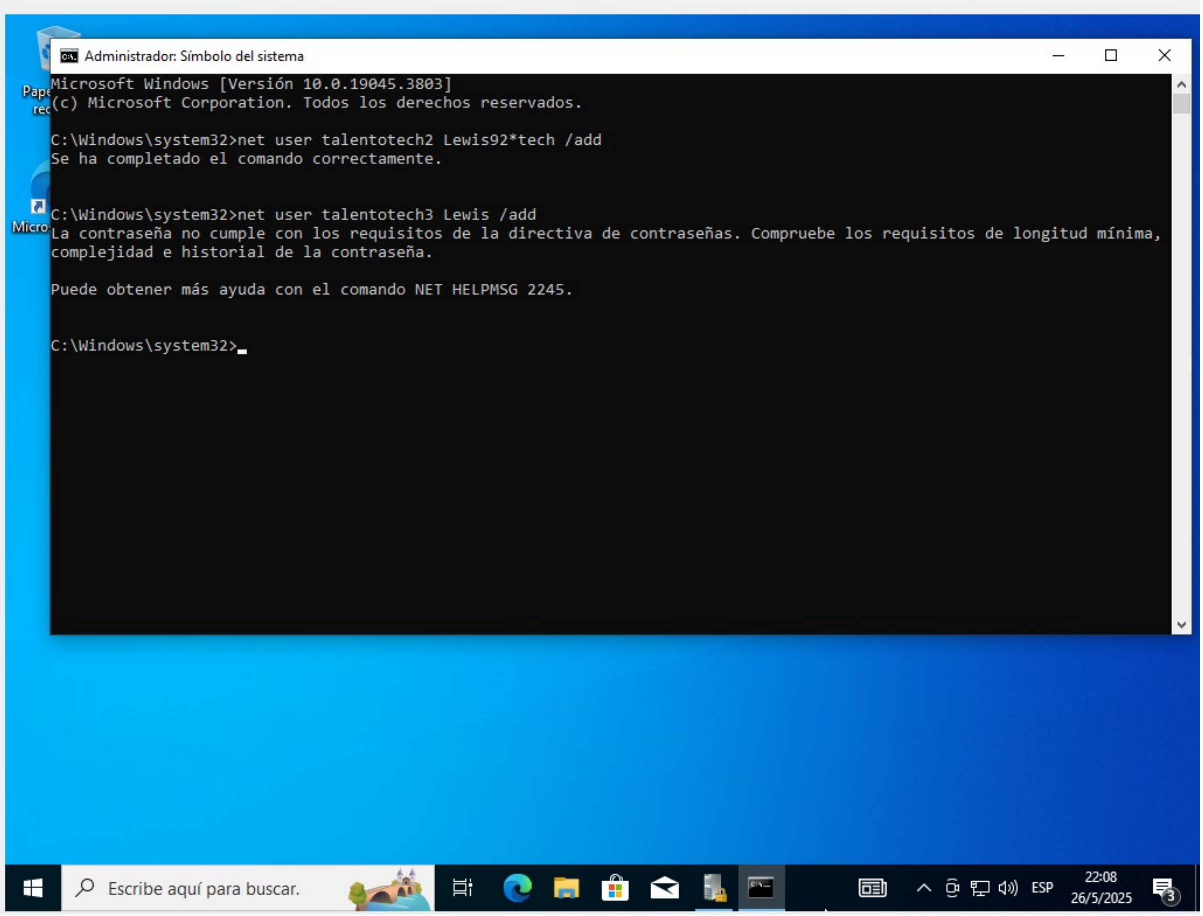
- **Paso 5:** Verificación del Bloqueo de Cuenta

R//

Para verificar el bloqueo de cuenta en Linux, intenta iniciar sesión varias veces con una contraseña incorrecta:



Windows:



- **Paso 6:** Documentación del Proceso

Entrega:
Los participantes deben preparar un informe que describa los pasos seguidos para configurar las políticas de contraseñas y los mecanismos de bloqueo de cuenta, incluyendo capturas de pantalla o ejemplos de comandos utilizados.